



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



VMware Avi Load Balancer Multi-CVE Control Plane Vulnerabilities

CVE / Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-07-22
Version	1.0
Author	Lost Boys Cyber
Report Type	CVE / Vulnerability Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | VMware Avi Load Balancer Multi-CVE Control Plane Vulnerabilities - CVE / Vulnerability Threat Intelligence Report

Published: 2026-07-22 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Vulnerability Metadata
 - 2.1. CVE Summary Table
 - 2.2. Fixed-Version Matrix
3. Source Review & Confidence
4. Vulnerability Details
5. Attack Scenarios
6. Threat Landscape & Exploitation Status
7. Affected Products and Exposure
8. Mitigation and Workarounds
9. Detection Engineering
 - 9.1. Detection Logic Summary
 - 9.2. Sigma Rule: Suspicious VMware Avi Controller Path Traversal or Admin API Probing
 - 9.3. KQL: Avi Controller Management Requests From Non-Admin Networks
 - 9.4. KQL: Possible Authentication Bypass Sequence
 - 9.5. SPL: Path Traversal Against Avi Controller Web Logs
10. Threat Hunting
 - 10.1. Hunt Hypotheses
 - 10.2. KQL: Controller Host Process Review
 - 10.3. KQL: Suspicious Configuration or Certificate Changes
 - 10.4. SPL: New or Rare Source IPs Reaching Avi Management
11. MITRE ATT&CK Mapping
12. Validation / Lab Testing
13. Recommended Actions Summary
14. Indicators, Observables, and Source Limitations
15. References

VMware Avi Load Balancer Multi-CVE Control Plane Vulnerabilities

1. Executive Summary

Broadcom disclosed VMSA-2026-0005 on 14 July 2026 for seven privately reported VMware Avi Load Balancer vulnerabilities affecting the Avi Controller / control plane. The combined advisory is critical because the cluster includes a network-reachable authentication bypass, authorization bypass, two remote-code-execution paths, privilege-escalation issues, and directory traversal. The highest-risk issue is CVE-2026-47865, a CVSSv3 9.8 authentication bypass that may allow a network attacker to access the Avi control plane without valid authentication.

Avi Load Balancer, formerly associated with VMware NSX Advanced Load Balancer, is often placed on or near high-value application delivery paths. Compromise of the controller plane can expose application delivery configuration, virtual service definitions, TLS and certificate management workflows, service-engine orchestration, administrative identities, and downstream routing decisions. Even where data-plane traffic is not directly internet-facing, a reachable management interface materially increases risk because several vulnerabilities are network-accessible and several follow-on paths require only authenticated or limited-authorized access.

Lost Boys Cyber assesses patching as urgent for internet-reachable, partner-reachable, or broadly internal Avi Controller management surfaces. Broadcom lists fixed versions 32.1.2, 31.2.2-2p3, and 30.2.7, and explicitly notes that 22.1.x deployments must upgrade to at least 30.2.7 or later. Broadcom lists no workarounds for the CVEs in the response matrix; therefore, exposure reduction, access control around the control plane, emergency credential review, and telemetry review should accompany version remediation.

As of this report generation on 2026-07-22, CISA KEV did not list CVE-2026-47865 through CVE-2026-47871, and quick open-source searches did not identify a confirmed public exploit chain. EPSS values were still low to modest on 2026-07-22. Those facts should not be read as low operational risk: the vulnerability set sits on a privileged control-plane product, includes unauthenticated access potential, and has no vendor workarounds beyond upgrading.

2. Vulnerability Metadata

Field	Value
Advisory	Broadcom VMSA-2026-0005 / Support Notification 37926
Product / Component	VMware Avi Load Balancer / Avi Controller control plane
Disclosure Date	2026-07-14 initial advisory; Broadcom portal last updated 2026-07-15
Advisory Severity	Critical
CVSSv3 Range	7.1 to 9.8
Affected Versions	32.1.1; 31.1.1 through 31.2.2; 30.1.1 through 30.2.6; 22.1.1 through 22.1.7
Fixed Versions	32.1.2; 31.2.2-2p3; 30.2.7; 22.1.x must upgrade to at least 30.2.7 or later
Workarounds	Broadcom lists none for the response matrix
Exploitation Status	No CISA KEV listing and no confirmed public exploit identified during this research pass; risk remains high due to control-plane impact

2.1. CVE Summary Table

CVE	Broadcom Description	Access / Preconditions	CVSSv3	Severity	Primary Risk
CVE-2026-47865	Authentication bypass in VMware Avi Load Balancer	Network access; no valid authentication required per vendor vector	9.8	Critical	Unauthenticated access to Avi control plane
CVE-2026-47866	Authorization bypass	Network access; limited or improper authorization boundary	8.3	Important	Access to a subset of the Avi control plane without proper authorization
CVE-2026-47867	Remote code execution	Network access; vendor vector says malicious user may access control plane and execute code	8.7	Important	Code execution against control-plane scope
CVE-2026-47868	Local privilege escalation	Local access	7.8	Important	Escalation to root on affected system
CVE-2026-47869	Remote code execution	Authenticated network access	8.7	Important	Authenticated code injection / execution
CVE-2026-47870	Privilege escalation	Authenticated network access	7.1	Important	Remote code execution as a consequence of privilege escalation
CVE-2026-47871	Directory traversal	Authenticated network access	8.8	Important	Arbitrary path traversal risk and potential sensitive-file exposure or write-path abuse depending on implementation

2.2. Fixed-Version Matrix

Product Version	Affected CVEs	Fixed Version	Notes
32.1.1	CVE-2026-47866, CVE-2026-47867, CVE-2026-47868, CVE-2026-47869, CVE-2026-47870, CVE-2026-47871	32.1.2	Broadcom recommends 32.1.2 as the most recent available version. CVE-2026-47865 is not listed for 32.1.1 in the response matrix.
31.1.1 - 31.2.2	CVE-2026-47865 through CVE-2026-47871	31.2.2-2p3	Critical due to inclusion of CVE-2026-47865.
30.1.1 - 30.2.6	CVE-2026-47865 through CVE-2026-47871	30.2.7	Critical due to inclusion of CVE-2026-47865.
22.1.1 - 22.1.7	CVE-2026-47865 through CVE-2026-47871	Upgrade to at least 30.2.7	Broadcom states 22.1.x must be upgraded to 30.2.7 or later.

3. Source Review & Confidence

Source	Contribution	Confidence
Broadcom VMSA-2026-0005 / Support Notification 37926	Canonical product scope, CVE list, fixed versions, CVSS vectors, lack of workarounds, and acknowledgements	High
GovCERT.HK A26-07-28	Government alert confirming impact classes: remote code execution, elevation of privilege, information disclosure, and security restriction bypass	High
CISA Known Exploited Vulnerabilities catalog, queried 2026-07-22	Confirms these CVEs were not present in KEV at query time	High for catalog status at query time
FIRST EPSS API, queried 2026-07-22	Provides early exploitation-probability signals for all seven CVEs	Medium; EPSS shifts daily and can lag exploit publication
SecurityWeek / Heise / secondary security-news coverage	Independent confirmation and defender context for severity and impact	Medium
Lost Boys Cyber synthesis	Attack scenarios, detection opportunities, operational prioritization	Medium; not based on exploit reproduction

The primary facts in this report are vendor-sourced. Analysis beyond the advisory is framed as defender prioritization rather than proof of active exploitation. No exploit was reproduced and no product logs from a client environment were available for validation.

4. Vulnerability Details

The vulnerability set targets the Avi Load Balancer control plane rather than a generic endpoint service. In operational terms, the control plane manages load-balancing policy, service-engine lifecycle, virtual services, certificates, SSL/TLS settings, health checks, pools, and administrative access paths. A control-plane weakness therefore has higher blast radius than a single web-application bug because it may allow an attacker to change routing, harvest sensitive configuration, degrade availability, or pivot into application-delivery infrastructure.

CVE-2026-47865 is the highest-priority item because Broadcom describes it as an authentication bypass where a malicious user with network access may access the Avi control plane by bypassing authentication. The CVSS vector published by Broadcom is AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H, meaning remote network access, low complexity, no privileges, no user interaction, and high impact to confidentiality, integrity, and availability.

CVE-2026-47866 lowers or breaks an authorization boundary. Broadcom describes access to a limited subset of the Avi control plane without proper authorization. Even if the exposed subset is narrow, this matters because Avi Controller administrative surfaces can disclose topology, service names, version data, and policy state that make later exploitation or social engineering easier.

CVE-2026-47867 and CVE-2026-47869 are both remote-code-execution issues. The first is described as network-accessible and capable of remote code execution after control-plane access; the second requires authenticated network access and enables code injection/execution. In a chained scenario, an attacker may first bypass authentication or authorization, then use a code-execution path if their reached surface satisfies its preconditions.

CVE-2026-47868 and CVE-2026-47870 are privilege-escalation issues. CVE-2026-47868 requires local access and may allow root-level execution. CVE-2026-47870 requires authenticated network access and may allow remote code execution as a privilege-escalation consequence. These should be treated as post-access accelerants: they increase the consequence of any weaker boundary that gives an attacker an initial foothold.

CVE-2026-47871 is a directory traversal vulnerability stemming from file-path validation flaws. Directory traversal bugs in control-plane products can enable sensitive-file read, unexpected file access, or write-path abuse depending on the affected endpoint and implementation details. Broadcom's public text does not provide endpoint-level detail, so defenders should avoid overfitting detections to a single path pattern.

5. Attack Scenarios

Scenario	Attacker Path	Likely Objective	Defensive Priority
Internet-exposed controller takeover attempt	Scan for Avi Controller UI/API, fingerprint version, attempt CVE-2026-47865 authentication bypass, enumerate configuration	Control-plane access, certificate/configuration theft, traffic-routing manipulation	Remove internet exposure, enforce VPN/privileged access path, patch immediately
Authenticated operator account abuse	Use compromised low-privilege account, API token, or SSO session; test authorization bypass or RCE preconditions	Expand privileges, execute code, alter virtual-service policy	Review accounts, rotate tokens, audit login and API activity, patch
Internal lateral movement	Compromised workstation or server reaches management VLAN; attacker targets Avi Controller because it manages high-value application delivery	Pivot into application-delivery infrastructure and disrupt availability	Segment controller access to admin hosts only, monitor east-west access
Local system escalation	Attacker obtains local shell through another vulnerability or exposed maintenance path; uses CVE-2026-47868 to escalate to root	Persistence, tampering with logs, full host compromise	Patch, restrict shell access, check local accounts and sudo/history telemetry
Directory traversal reconnaissance	Authenticated attacker probes file/path parameters after initial access	Read sensitive files or stage follow-on exploitation	Monitor suspicious path traversal markers and unusual API error patterns

6. Threat Landscape & Exploitation Status

At query time, CISA KEV catalog version 2026.07.21 did not contain CVE-2026-47865, CVE-2026-47866, CVE-2026-47867, CVE-2026-47868, CVE-2026-47869, CVE-2026-47870, or CVE-2026-47871. FIRST EPSS on 2026-07-22 returned low to modest values: CVE-2026-47865 at 0.00665, CVE-2026-47866 at 0.00426, CVE-2026-47867 at 0.00682, CVE-2026-47868 at 0.00147, CVE-2026-47869 at 0.00682, CVE-2026-47870 at 0.00390, and CVE-2026-47871 at 0.00902.

Those exploitation signals are early and should be interpreted carefully. Edge-management and application-delivery platforms often move from advisory to scanning quickly once enough detail appears in patch diffs, documentation, or proof-of-concept research. The presence of a CVSS 9.8 unauthenticated control-plane bypass changes prioritization even before KEV or EPSS increases.

Public reporting by security-news outlets echoed Broadcom's main risk themes: authentication bypass, authorization bypass, remote code execution, privilege escalation, and directory traversal across supported Avi Load Balancer release lines. We did not identify a named threat actor campaign tied to these CVEs during this research pass.

7. Affected Products and Exposure

Exposure Pattern	Why It Matters	Priority
Avi Controller UI/API reachable from the internet	CVE-2026-47865 requires network access and no privileges; exposed control planes	Emergency

	are the highest-likelihood scan targets	
Controller reachable from broad corporate networks	Internal compromise, phishing, VPN compromise, or unmanaged device access can provide the required network path	Critical
Controller reachable only from bastion / PAM / admin subnet	Risk is materially lower but still patch-required because authenticated RCE and local escalation remain relevant	High
22.1.x deployment	Broadcom does not list a 22.1.x patch; upgrade to at least 30.2.7 or later is required	Critical migration path
32.1.1 deployment	Broadcom lists six affected CVEs, excluding CVE-2026-47865, fixed in 32.1.2	High
Patched to 32.1.2 / 31.2.2-2p3 / 30.2.7	Reduced vulnerability exposure; still validate access controls and review logs around advisory window	Medium

8. Mitigation and Workarounds

Broadcom lists no workarounds for the response matrix. The defensive plan should therefore combine patching with immediate exposure reduction and post-patch verification.

Priority	Owner	Action	Verification
Emergency	Network / Platform	Remove Avi Controller management access from the public internet and restrict to VPN, bastion, or privileged admin subnets	External scan confirms UI/API is not reachable from untrusted networks
Emergency	Platform	Upgrade affected versions to 32.1.2, 31.2.2-2p3, or 30.2.7; upgrade 22.1.x to at least 30.2.7	Controller reports fixed version and maintenance window record is attached
Critical	IAM / Platform	Review local users, SSO mappings, API tokens, service accounts, and recently created admin roles	No unexplained privileged accounts or tokens remain active
Critical	SOC	Review authentication, authorization, API, and system logs from at least 14 days before disclosure through remediation	Hunt queries completed and exceptions triaged
High	Security Engineering	Segment management interfaces, enforce MFA/SSO where supported, and block direct workstation-to-controller access except from admin jump hosts	Firewall/PAM policy matches intended access path
High	Backup / Platform	Confirm backup integrity and	Restore test or checksum-

		offline access to controller configuration backups before and after upgrade	backed backup evidence exists
Medium	Vulnerability Management	Add all seven CVEs and affected version ranges to scanning and asset inventory logic	Inventory shows every Avi Controller with version and owner

9. Detection Engineering

Detection should focus on control-plane access anomalies, authentication bypass indicators, path traversal probes, unusual API use, and management-plane reachability rather than a brittle exploit signature. The public advisory does not provide endpoint names or payload structure, so signatures below are designed as starting points for logs from reverse proxies, WAFs, controllers, EDR, and network telemetry.

9.1. Detection Logic Summary

Signal	Telemetry Source	Analytic Goal
Avi Controller management requests from non-admin networks	Firewall, reverse proxy, WAF, Zeek, load balancer telemetry	Identify exploit attempts and unauthorized management-plane access
Successful or anomalous API requests without normal login/session sequence	Avi audit logs, SSO logs, reverse proxy logs	Detect authentication bypass or session abnormality
Path traversal markers in Avi Controller requests	WAF/proxy/controller HTTP logs	Detect CVE-2026-47871-style probing
Administrative changes after unusual source IP or account	Avi audit logs, SIEM identity logs	Detect post-access configuration tampering
Shell or process anomalies on Controller hosts	EDR, Linux auditd, syslog	Detect RCE or local privilege escalation follow-on activity

9.2. Sigma Rule: Suspicious VMware Avi Controller Path Traversal or Admin API Probing

<pre> title: Suspicious VMware Avi Controller Path Traversal or Admin API Probing id: 8cc92926-65fe-4f4c-a824-6ec9b8d5c128 status: experimental description: Detects path traversal markers or suspicious API access against VMware Avi Load Balancer / NSX Advanced Load Balancer controller management surfaces after VMSA-2026-0005. author: Lost Boys Cyber date: 2026-07-22 references: - https://support.broadcom.com/web/ecx/support-content-notification/-/external/content/SecurityAdvisories/0/37926 logsource: category: webserver detection: selection_avi_path: cs-uri-stem contains: - '/api/' - '/login' - '/portal' - '/controller' selection_traversal: cs-uri-query contains: - '../' - '..%2f' - '%2e%2e%2f' </pre>
--


```

- '..\\'
- '%2e%2e%5c'
cs-uri-stem|contains:
- '../'
- '..%2f'
- '%2e%2e%2f'
condition: selection_avi_path and selection_traversal
fields:
- src_ip
- cs-host
- cs-uri-stem
- cs-uri-query
- sc-status
falsepositives:
- Vulnerability scanner testing authorized by the organization
- Web application security testing against an isolated lab controller
level: high

```

9.3. KQL: Avi Controller Management Requests From Non-Admin Networks

```

let lookback = 14d;
let AviControllerHosts = dynamic(['avi-controller.example.com','nsx-alb-controller.example.com']);
let ApprovedAdminCidrs = dynamic(['10.10.10.0/24','10.20.30.0/24']);
DeviceNetworkEvents
| where Timestamp > ago(lookback)
| where RemoteUrl has_any (AviControllerHosts) or RemotePort in (443, 8443)
| extend SrcIp = tostring(LocalIP), Dst = tostring(RemoteUrl)
| where not(ipv4_is_in_any_range(SrcIp, ApprovedAdminCidrs))
| summarize FirstSeen=min(Timestamp), LastSeen=max(Timestamp), Attempts=count(),
Ports=make_set(RemotePort), Processes=make_set(InitiatingProcessFileName) by DeviceName, SrcIp, Dst
| where Attempts > 0
| order by Attempts desc

```

9.4. KQL: Possible Authentication Bypass Sequence

```

let lookback = 14d;
let AviHosts = dynamic(['avi-controller.example.com','nsx-alb-controller.example.com']);
let LoginTerms = dynamic(['/login','/api/login','/session']);
let AdminTerms = dynamic(['/api/', '/admin', '/controller', '/cloud', '/virtualservice', '/serviceengine']);
DeviceNetworkEvents
| where Timestamp > ago(lookback)
| where RemoteUrl has_any (AviHosts)
| summarize Urls=make_set(RemoteUrl, 100), FirstSeen=min(Timestamp), LastSeen=max(Timestamp),
Count=count() by DeviceName, InitiatingProcessAccountName, InitiatingProcessFileName, LocalIP,
bin(Timestamp, 30m)
| extend SawLogin = array_length(set_intersect(Urls, LoginTerms)) > 0
| extend SawAdmin = array_length(set_intersect(Urls, AdminTerms)) > 0 or tostring(Urls) has_any
(AdminTerms)
| where SawAdmin and not(SawLogin)
| order by LastSeen desc

```

9.5. SPL: Path Traversal Against Avi Controller Web Logs

```

index=web sourcetype IN (nginx:access,apache:access,pan:traffic,proxy) (host="*avi*" OR url="*avi*" OR
dest_port IN (443,8443))
("..../" OR "..%2f" OR "%2e%2e%2f" OR "..\\" OR "%2e%2e%5c")
| stats count min(_time) as first_seen max(_time) as last_seen values(url) as urls values(status) as
status by src_ip dest host user_agent
| convert ctime(first_seen) ctime(last_seen)
| sort - count

```

10. Threat Hunting

Hunters should answer four questions: who can reach Avi Controllers, whether any access occurred from unexpected sources, whether administrative changes happened around suspicious sessions, and whether controller hosts show process or filesystem anomalies consistent with RCE or privilege escalation.

10.1. Hunt Hypotheses

Hypothesis	Why It Matters	Evidence to Collect
A non-admin source accessed the controller management plane before patching	CVE-2026-47865 and related CVEs require network access	Firewall/proxy logs, VPN identity, endpoint owner
An account or token performed unusual API calls without normal login sequence	Authentication or authorization boundary may have been bypassed	Avi audit logs, SSO logs, reverse proxy session sequence
Controller configuration changed unexpectedly	Control-plane compromise may be used to alter traffic routing or certificates	Configuration diffs, audit event IDs, change tickets
Controller host spawned unexpected child processes	RCE or local privilege escalation may create shell/process artifacts	EDR process telemetry, auditd execve logs, syslog

10.2. KQL: Controller Host Process Review

```
let lookback = 30d;
let ControllerNames = dynamic(['avi-controller-01','avi-controller-02']);
DeviceProcessEvents
| where Timestamp > ago(lookback)
| where DeviceName has_any (ControllerNames)
| where FileName in~
('sh','bash','dash','python','python3','perl','ruby','curl','wget','nc','ncat','socat','openssl')
or ProcessCommandLine has_any ('/tmp/','/var/tmp/','chmod +x','curl http','wget http','bash
-c','python -c')
| project Timestamp, DeviceName, InitiatingProcessFileName, FileName, ProcessCommandLine, AccountName,
ReportId
| order by Timestamp desc
```

10.3. KQL: Suspicious Configuration or Certificate Changes

```
let lookback = 30d;
let ChangeTerms =
dynamic(['virtualservice','serviceengine','pool','cloud','certificate','sslkeyandcertificate','systemco
nfiguration','useraccount','role']);
CommonSecurityLog
| where TimeGenerated > ago(lookback)
| where DeviceVendor has_any ('VMware','Broadcom','Avi') or DestinationHostName has 'avi'
| where RequestURL has_any (ChangeTerms) or Message has_any (ChangeTerms)
| where RequestMethod in~ ('POST','PUT','PATCH','DELETE') or Message has_any
('created','updated','deleted','modified')
| summarize FirstSeen=min(TimeGenerated), LastSeen=max(TimeGenerated), Events=count(),
Methods=make_set(RequestMethod), Urls=make_set(RequestURL, 50), Users=make_set(SourceUserName) by
SourceIP, DestinationHostName
| order by LastSeen desc
```

10.4. SPL: New or Rare Source IPs Reaching Avi Management

```
index=network OR index=proxy (dest_port=443 OR dest_port=8443) (dest_host="*avi*" OR uri_host="*avi*"
OR dest_ip IN ("<AVI_CONTROLLER_IP_1>","<AVI_CONTROLLER_IP_2>"))
| bin _time span=1d
| stats count dc(_time) as active_days min(_time) as first_seen max(_time) as last_seen values(user) as
users values(user_agent) as user_agents by src_ip dest_ip dest_host
| eventstats avg(count) as avg_count stdev(count) as stdev_count by src_ip
| where active_days=1 OR count > avg_count + (3*stdev_count)
| convert ctime(first_seen) ctime(last_seen)
| sort - count
```

11. MITRE ATT&CK Mapping

Technique	Name	Evidence / Rationale
T1190	Exploit Public-Facing Application	Internet- or network-reachable Avi

		Controller management services may be exploited through authentication bypass, authorization bypass, RCE, or traversal flaws.
T1133	External Remote Services	Exposed management interfaces, VPN-only controller access, and administrative portals are likely initial access routes when reachable from outside trusted admin networks.
T1068	Exploitation for Privilege Escalation	CVE-2026-47868 and CVE-2026-47870 are privilege-escalation issues.
T1059	Command and Scripting Interpreter	Successful RCE commonly results in shell, Python, or other command-interpreter execution on Linux-based appliances/controllers. This is a hunt mapping, not vendor-confirmed behavior.
T1083	File and Directory Discovery	Directory traversal and post-access reconnaissance may involve file/path probing.
T1098	Account Manipulation	Control-plane access may allow creation or modification of administrative accounts, API tokens, or roles.
T1562	Impair Defenses	A privileged attacker may tamper with logs, disable telemetry, or alter routing/security policy after control-plane compromise.

12. Validation / Lab Testing

Lost Boys Cyber did not reproduce exploitation of any CVE in a lab. Validation completed for this report consisted of source collection, vendor-advisory extraction, KEV catalog query, EPSS API query, open-source exploit/public-report searches, and report-render QA.

Validation Step	Result
Broadcom advisory extraction	Extracted CVE list, descriptions, CVSS scores, fixed-version matrix, and no-workaround statement from Support Notification 37926.
GovCERT.HK confirmation	Confirmed government alert describing possible RCE, elevation of privilege, information disclosure, and security restriction bypass impacts.
CISA KEV check	Queried 2026-07-22; none of the seven CVEs were present in KEV.
FIRST EPSS check	Queried 2026-07-22; all seven CVEs returned low-to-modest EPSS values.
Public exploit search	No confirmed public exploit chain identified in quick open-source search.

Detection content	Created Sigma, KQL, and SPL starting points for management-plane access and path traversal hunting.
-------------------	---

13. Recommended Actions Summary

Priority	Owner	Action
Emergency	Platform Engineering	Patch or upgrade every affected Avi Controller according to Broadcom fixed-version guidance.
Emergency	Network Security	Restrict controller UI/API to privileged admin paths only; remove internet and broad-corporate reachability.
Critical	SOC	Run the included hunts against at least 30 days of proxy, firewall, EDR, SSO, and controller audit logs.
Critical	IAM	Rotate API tokens and review administrator accounts if any suspicious management-plane access is identified.
High	Vulnerability Management	Add version checks for 22.1.x, 30.1.1-30.2.6, 31.1.1-31.2.2, and 32.1.1 to recurring scans.
High	Platform Engineering	Preserve controller configuration backups and perform post-upgrade health checks for virtual services, pools, certificates, and service engines.
Medium	Detection Engineering	Convert the included generic analytics into environment-specific rules using known controller hostnames, admin CIDRs, and log fields.

14. Indicators, Observables, and Source Limitations

No exploit infrastructure, malware hashes, attacker IP addresses, or file indicators were validated for this vulnerability set during this research pass. The useful observables are therefore environment-specific: Avi Controller hostnames, management IPs, admin subnet allowlists, URL paths in controller/proxy logs, account names, API tokens, and configuration-change events.

Observable Type	Example / Placeholder	Use
Controller hostnames	avi-controller.example.com, nsx-alb-controller.example.com	Seed proxy, DNS, EDR, and SIEM hunts
Management ports	443, 8443, organization-specific admin ports	Identify management-plane access attempts
Suspicious path markers	../, ../%2f, %2e%2e%2f, ../, %2e%2e%5c	Directory traversal probe detection
Administrative objects	virtualservice, serviceengine, pool, certificate, sslkeyandcertificate	Configuration-change review

Account/token artifacts	new administrator, changed role, API token creation	Detect post-access persistence or privilege expansion
-------------------------	---	---

15. References

- [1] Broadcom Support Notification 37926 / VMSA-2026-0005: VMware Avi Load Balancer addresses multiple vulnerabilities — <https://support.broadcom.com/web/ecx/support-content-notification/-/external/content/SecurityAdvisories/0/37926>
- [2] GovCERT.HK Security Alert A26-07-28: Multiple Vulnerabilities in VMware Avi Load Balancer — https://www.govcert.gov.hk/en/alerts_detail.php?id=1968
- [3] CISA Known Exploited Vulnerabilities Catalog — <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>
- [4] FIRST EPSS API — <https://api.first.org/data/v1/epss>
- [5] SecurityWeek: 7 Severe Vulnerabilities Patched in VMware Avi Load Balancer — <https://www.securityweek.com/7-severe-vulnerabilities-patched-in-vmware-avi-load-balancer/>
- [6] Heise: VMware Avi Load Balancer critical vulnerability allows bypassing login — <https://www.heise.de/en/news/VMware-Avi-Load-Balancer-Critical-vulnerability-allows-bypassing-login-11368944.html>